



RAVEN SECURITY
PROTECCIÓN DIGITAL INTELIGENTE

Plan de Respuesta a Incidentes y Sistema de Gestión

ANALISTA

JULIO LEANDRO FRAGA PIROLA

Fecha de Consolidación: 2 de Mayo de 2026

Version:1.0

ÍNDICE

1. Plan de Respuesta a Incidentes (Metodología NIST SP 800-61 Rev. 2)	1
• A. Preparación (Aseguramiento Proactivo)	1
• B. Detección y Análisis (Identificación del Vector)	2
• C. Contención, Erradicación y Recuperación	3
◦ <i>Contención Inmediata</i>	3
◦ <i>Erradicación Definitiva</i>	4
◦ <i>Recuperación Segura</i>	5
• D. Actividades Post-Incidente (Lecciones Aprendidas)	6
2. Mecanismos de Protección y Resguardo de Datos	7
• Estrategia de Respallos de Continuidad 3-2-1	7
• Cifrado de Datos Sensibles (Data Protection)	8
• Controles de Acceso Estricto (Segmentación DMZ / LAN)	9
3. Sistema de Gestión de Seguridad de la Información (SGSI - ISO/IEC 27001:2022)	10
• A. Análisis y Evaluación de Riesgos (Cláusula 6.1.2)	10
• B. Declaración de Aplicabilidad (SoA - Controles del Anexo A)	11



Plan de Respuesta a Incidentes (NIST SP 800-61) y Sistema de Gestión (ISO 27001)

1. Plan de Respuesta a Incidentes (Metodología NIST SP 800-61 Rev. 2)

El ciclo de vida de respuesta a incidentes se ha diseñado específicamente para neutralizar vectores de ataque dirigidos a nuestra infraestructura perimetral y de aplicaciones (servidor web, bases de datos y almacenamiento de archivos).

A. Preparación (Aseguramiento Proactivo)

- **Controles Técnicos:** Implementación de un sistema de monitorización centralizado (SIEM/Syslog) configurado con alertas tempranas ante picos anómalos de tráfico en puertos críticos (TCP/22 para SSH, TCP/21 para FTP).
- **Gestión de Vulnerabilidades:** Establecimiento de auditorías de configuración mensuales mediante herramientas de escaneo y un programa estricto de parches automatizados (*Patch Management*) en el servidor Debian para garantizar que ningún binario de servicios quede obsoleto.
- **Capacitación:** Simulacros trimestrales del equipo técnico para el despliegue rápido de políticas de contención.

B. Detección y Análisis (Identificación del Vector)

- **Indicadores de Compromiso (IoC):** Monitoreo automatizado de registros del sistema (journalctl, /var/log/auth.log y logs de auditoría de MySQL) buscando patrones de ataques de fuerza bruta, intentos fallidos de login de la cuenta root, o modificaciones de archivos en texto plano (.bash_history, .mysql_history).
- **Validación:** Clasificación del incidente según su impacto (ej. exfiltración de bases de datos califica como incidente de Prioridad Crítica). Notificación automática al equipo de Respuesta a Incidentes (CSIRT).

C. Contención, Erradicación y Recuperación (Mitigación del Ataque Replicado)

Ante un ataque similar al sufrido el 08 de octubre (intrusión SSH, explotación de permisos laxos y exfiltración de Base de Datos), el procedimiento operativo estricto es:

1. Contención Inmediata:

- *Aislamiento de Red:* Modificación inmediata de las reglas en el Firewall perimetral (Cisco ASA) para denegar todo el tráfico entrante y saliente del servidor Debian afectado, mitigando la exfiltración activa.
- *Revocación de Sesiones:* Forzar el cierre de todas las sesiones activas en la terminal y congelar el estado de la memoria RAM para el posterior análisis forense antes de reiniciar servicios.

2. Erradicación Definitiva:

- *Preservación Forense:* Generación de una imagen en crudo (.raw) del disco para resguardar la evidencia física y la cadena de custodia.
- *Limpieza de Persistencias:* Identificación y eliminación de cualquier *backdoor* o tarea programada (cronjob) inusual. Eliminación de usuarios huérfanos o con privilegios excesivos detectados en la base de datos de WordPress.

3. Recuperación Segura:

- *Saneamiento de Permisos:* Reaplicación estricta de la política de privilegio mínimo a nivel de sistema de archivos (directorios a 755 y archivos a 644), erradicando cualquier configuración insegura (777).
- *Restauración:* Despliegue de los servicios desde imágenes base conocidas y limpias, importando únicamente los datos de la base de datos validados desde un respaldo inmutable anterior al incidente.

D. Actividades Post-Incidente (Lecciones Aprendidas)

- Elaboración del informe técnico *Post-Mortem*.
- Revisión de las brechas de configuración encontradas (como la presencia previa de credenciales débiles).
- Actualización de las reglas de correlación en el cortafuegos y sistemas de detección basados en las direcciones IP y firmas del atacante.

2. Mecanismos de Protección y Resguardo de Datos

Para neutralizar la recurrencia de vectores de explotación concurrentes y salvaguardar los activos de información crítica, se documentan las siguientes salvaguardas tecnológicas:

- **Estrategia de Respallos de Continuidad 3-2-1:**
 - **3 Copias:** Un conjunto de producción activo y dos réplicas de respaldo completas (archivos del CMS WordPress y volcados estructurados de MySQL).
 - **2 Soportes Diferentes:** Almacenamiento local rápido en infraestructura NAS dedicada para recuperaciones operativas rápidas y almacenamiento secundario de larga retención.
 - **1 Copia Off-site (Immutable):** Envío cifrado de los respaldos a un repositorio Cloud externo aislado geográficamente, configurado con políticas de retención (*WORM: Write Once, Read Many*) para imposibilitar su borrado o cifrado en caso de un ataque de Ransomware lateral.
- **Cifrado de Datos Sensibles (Data Protection):**
 - *Datos en Tránsito:* Cifrado mandatorio de todas las conexiones administrativas mediante protocolos seguros (reemplazo de FTP estándar por FTPS/SFTP y deshabilitación del inicio de sesión por contraseña en SSH a favor de intercambio de llaves criptográficas RSA de 4096 bits).
 - *Datos en Reposo y Credenciales:* Cifrado de la base de datos y ofuscación irreversible de identidades mediante algoritmos de hashing robustos de última generación (**Yescrypt/SHA-512** a nivel de sistema operativo Debian y esquemas con salado dinámico para la capa aplicativa).
- **Controles de Acceso Estrictos:**
 - Segmentación total de redes mediante la separación del servidor web de producción en una Zona Desmilitarizada (DMZ) dedicada, impidiendo de forma lógica que cualquier vulneración en el servidor web de cara al público permita el salto directo o el escaneo hacia los equipos de la red corporativa interna (LAN).

3. Sistema de Gestión de Seguridad de la Información (SGSI-ISO/IEC 27001:2022)

Para estructurar la seguridad de Raven Security bajo estándares internacionales, se define el núcleo estratégico del SGSI alineado con la norma ISO 27001:

A. Análisis y Evaluación de Riesgos (Cláusula 6.1.2)

Se utiliza una matriz de riesgo cualitativa para identificar el impacto y la probabilidad de amenazas sobre nuestros activos de información:

Activo de Información	Amenaza Identificada	Impacto	Probabilidad	Riesgo Inicial	Tratamiento del Riesgo
Servidor de Base de Datos (MySQL)	Exfiltración de datos / Fuerza Bruta	Crítico	Alta	Muy Alto	Mitigar mediante rotación criptográfica (Hashes SHA-512) y segmentación .
Código Fuente / CMS Web	Modificación no autorizada de archivos	Alto	Media	Alto	Mitigar mediante control estricto de permisos (644/755) y monitoreo.
Canales de Gestión (SSH/FTP)	Intercepción de tráfico / Acceso root	Crítico	Media	Alto	Mitigar eliminando login root y cifrando el transporte (SFTP).

B. Declaración de Aplicabilidad (SoA - Controles del Anexo A)

Selección y justificación de controles clave de la norma ISO 27001:2022 para mitigar las causas raíz detectadas en la auditoría:

- **Control A.5.15 - Gestión de contraseñas:** Establecimiento de una política corporativa que prohíbe el uso de claves por defecto o débiles (como "123456"). Requisito obligatorio de complejidad, longitud mínima y rotación periódica.
- **Control A.8.12 - Seguridad en las redes:** Diseño de la topología de red utilizando el cortafuegos perimetral para aislar los servidores públicos en una DMZ de los sistemas de almacenamiento interno.
- **Control A.8.20 - Privilegios de acceso basados en roles:** Restricción absoluta del uso de la cuenta genérica root. Las tareas de administración técnica deben ejecutarse mediante cuentas nominales asociadas a registros individuales de auditoría.
- **Control A.8.14 - Reducción de vulnerabilidades técnicas:** Creación de un flujo de trabajo permanente para el escaneo de dependencias antiguas y parches inmediatos de sistemas operativos fuera de soporte.



RAVEN SECURITY
PROTECCIÓN DIGITAL INTELIGENTE